

-

File No.: EXP202102430

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: THE GROUPING OF BODIES OF THE ADMINISTRATION OF PENITENTIARY INSTITUTIONS (ACAIP) (hereinafter the claimant party 1), THE ASSOCIATION OF PENITENTIARY WORKERS "YOUR ABANDONMENT CAN KILL ME" (hereinafter the claimant party 2), and THE PROFESSIONAL ASSOCIATION OF PRISON OFFICERS (hereinafter, the claimant party 3) filed a complaint with the Spanish Agency for Data Protection on 14/09/2021, 19/09/2021, and 21/09/2021 respectively. The complaint is directed against the GENERAL SECRETARIAT OF PENITENTIARY INSTITUTIONS with NIF S2813060G (hereinafter, SGIP). The reasons for the complaint are as follows:

They report the leakage of images captured by the video surveillance system of the Villena penitentiary center (Alicante), in which the aggression of some officials against a prisoner is observed. According to their statements, the images apparently only prompted a confidential internal investigation to determine possible disciplinary responsibilities, although the press has reported the events and disseminated the video. Along with the notification, links to the news containing the reported events are provided, where the video with the images can be viewed.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the SGIP for analysis and to inform this Agency within one month of the actions taken to comply with the requirements established in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on 06/10/2021 as evidenced by the acknowledgment of receipt in the file.

THIRD: On December 14, 2021, in accordance with Article 65 of the LOPDGDD, the complaints submitted by the claimant parties were admitted for processing.

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following details:

Date on which the reported events took place: September 9, 2021

The background information recorded in the information systems is as follows:

After the complaint was forwarded to the respondent party on October 6, 2021, a response was received by this Agency on November 5, 2021, from the General Subdirectorate of Analysis and Inspection of the SGID stating that:

(...)

On December 14, 2021, and January 4, 2022, the claimant parties were notified of the admission for processing.

On January 17, 2022, the Spanish Agency for Data Protection agreed to carry out the present investigative actions in relation to the reported events.

INVESTIGATED ENTITIES

During the present actions, the following entities have been investigated:

GENERAL SECRETARIAT OF PENITENTIARY INSTITUTIONS with NIF S2813060G located at C/ ALCALA, 38 - 40 - 28014 MADRID (MADRID)

RESULT OF THE INVESTIGATIVE ACTIONS

After a request for information was made to the respondent party on February 9, 2022, a response was

received on February 19 from the General Subdirectorate of Institutional Relations and Territorial Coordination stating that regarding the requested information:

1. Purpose of the processing related to the leaked recordings and applicable regulations: Organic Law 3/2018 and/or Organic Law 7/2021, as well as the other details of the Activity Register of said processing.

"in accordance with Article 32 of LO 7/21, of May 26, on personal data processed for the purposes of prevention, detection, investigation, and prosecution of criminal offenses and enforcement of criminal sanctions, which states:

- The video surveillance processing in penitentiary establishments aims to record the images obtained by the different video surveillance systems installed for controlling access and movement in penitentiary centers.
- The applicable regulations and its legitimizing basis are those of Article 11 of LO 7/21, of May 26, on personal data processed for the purposes of prevention, detection, investigation, and prosecution of criminal offenses and enforcement of criminal sanctions.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/12

- The categories of data processed consist of images of vehicles and persons accessing and remaining in penitentiary establishments.
- Their transfer to the State Security Forces and Corps, the Ombudsman, the Public Prosecutor's Office, and Courts in the exercise of their assigned functions is foreseen, without international transfer being contemplated.
- The entity responsible for the processing is the General Director of Criminal Execution and Social Reintegration of the General Secretariat of Penitentiary Institutions, C/Alcalá, 38-40, 28014, Madrid, with the directors of each establishment where the recording takes place being delegated responsible parties.

Attached is a report from the General Subdirectorate of Analysis and Inspection competent in the matter.

This report provides the following information:

(...)

CONCLUSIONS

Preliminary Information 2021/122 was opened to investigate the events that occurred on 16/8/21 at the Center and was sent to the Penitentiary Surveillance Court and the Guard Court of Villena.

Due to the subsequent dissemination of the images of this incident, an investigation was initiated which opened Preliminary Information 131/2021 to determine the responsibility and circumstances that took place in the dissemination of the images, resulting in a breach of the principle of confidentiality and secrecy that governs the conduct duty of public function.

Regarding the determination of authorship in the dissemination of the images, it has not been possible to establish it, nor where the breach of the confidentiality principle in their processing may have occurred.

The respondent claims that they are covered for the processing of the images by Article 11 of Organic Law 7/2021 and Instructions 5/2006 and 6/2007 on communication and clarification of serious regulatory facts, and the duty to report to judicial authorities in accordance with the provisions of Article 262 of the Criminal Procedure Law.

They provide information about the CCTV system, supported by two instructions:

- Instruction 3/2015 on video surveillance in penitentiary establishments dated May 18, 2015, which was in force at the time of the claimed events and the claim; and
- Instruction 4/2022 regulating the processing of personal data obtained through the recording of images and sounds by the existing video surveillance systems in various penitentiary establishments dated July 28, 2022, along with the Guide for the preparation of the Protocol for recording, storage, and processing of images obtained through the video surveillance systems of penitentiary

establishments, dated July 28, 2022, in development of Instruction No. 4/2022.

That is to say, the 2022 instruction and its action protocol detailing security measures and access are dated after the claimed events and the claim, taking effect 15 days after their receipt in the centers, and a period of 3 months was given to the Management Board to adapt the procedures.

The first instruction refers to the LOPD/RLPD and these last two documents refer to Organic Law 3/2018, Organic Law 7/2021, and Regulation (EU) 2016/679.

It provides the status of the judicial procedure as of June: Preliminary Proceedings 2021/450 Court of First Instance and Instruction No. 1 of Villena.

FOURTH: On November 29, 2022, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

Upon notification of the initiation agreement, the SGIP submitted a written statement of allegations, in which it essentially stated:

- The SGIP argues that any decision made in the disciplinary field must be governed by the principle of presumption of innocence.
- The SGIP argues that, in addition to the images being known to the Penitentiary Administration (Alicante I Penitentiary Center and General Subdirectorate of Analysis and Inspection), there were two judicial bodies to which the aforementioned images were sent by legal imperative (Guard Instruction Court and Penitentiary Surveillance Court), and that they cannot be held responsible for the use and treatment given by these.
- The SGIP argues that the need for broad access profiles originates from the very organization and work needs of the General Subdirectorate of Analysis and Inspection, and that regarding the lack of traceability, it is indeed possible to know which person accesses which images - that is, access to the shared folder leaves a trace - the impossibility of identification referred to was regarding the specific person who made the images public.

FIFTH: On 05/05/2023, the instructor of the procedure agreed to carry out the following tests:

"It is also requested that the following documentation related to the Preliminary Information procedure 2021/122 be sent:

Detail and documentary accreditation:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/12

- a) Users who had access to the system.
- b) Roles assigned to each of them, functions, and access permissions granted.
- c) Existing procedures for user management (detailing the processes for onboarding, offboarding, identification, authentication, and logical access control).
- d) Analysis of the logs of users who had access to the system.

On May 23, 2023, a written response was received fulfilling the requested evidence.

SIXTH: On June 8, 2023, a resolution proposal was formulated, proposing:

That the Director of the Spanish Agency for Data Protection imposes on the GENERAL SECRETARIAT OF PENITENTIARY INSTITUTIONS, with NIF S2813060G, a warning sanction for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

Once the resolution proposal was notified, the SGIP submitted a new document stating:

"In the Reference File, the information provided throughout the procedure is reproduced, remaining available for the implementation of those technical and organizational measures as far as budgetarily possible."

In view of all that has transpired, the Spanish Agency for Data Protection considers the following facts proven in this procedure,

PROVEN FACTS

FIRST: According to the documentation in the file, there is a lack of profiling, as any inspector could access the recorded images, without it being specified whether they are authorized to do so, whether a specific system needs to be enabled, or whether access to the images is free for all inspectors, as the response to the requested evidence did not clarify this aspect.

SECOND: According to the documentation in the file, there is a lack of traceability, as it has not been demonstrated that there are records of the users who may have accessed the system.

LEGAL GROUNDS

I

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/12

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

In response to the allegations presented by the accused entity, the following should be noted:

-The SGIP alleges that any decision made in the disciplinary field must be governed by the principle of the presumption of innocence.

In this regard, this Agency expresses its total and absolute agreement, indicating that all sanctioning procedures are conducted according to the provisions established in Articles 64 and following of the LOPDGDD, scrupulously respecting the established legislation.

The presumption of innocence, a fundamental right of citizens according to Article 24.2 of the Constitution and Article 6.2 of the European Convention on Human Rights, is expressly included in our legal system for sanctioning administrative procedures in Article 53.2.b) of Law 39/15, where among the rights of the interested party in the sanctioning administrative procedure, they shall have the right "To the presumption of non-existence of administrative responsibility until proven otherwise."

As established by the STS 28.04.2016 (RC 677/2014): "It should be noted that the right to the presumption of innocence, which applies without exception in the field of sanctioning administrative procedures, as referred to by the Constitutional Court in ruling 66/2007, of March 27, implies that 'no sanction may be imposed that does not have a basis in prior lawful evidentiary activity,' and also entails the recognition of the right to a due sanctioning administrative procedure with all guarantees, which respects the principle of contradiction and in which the alleged responsible party has the opportunity to defend their own positions, prohibiting the initiation of sanctioning files when the non-existence of rational indications of a committed offense is clearly or manifestly appreciable."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/12

"conduct that constitutes an infringement, or in which the unlawfulness or culpability is absent."

- The SGIP argues that, in addition to the fact that the images were known to the Penitentiary Administration (Alicante I Penitentiary Center and General Subdirectorate of Analysis and Inspection),

there were two judicial bodies to which the aforementioned images were sent by legal imperative (Guardia Instruction Court and Penitentiary Surveillance Court), and that they cannot be held responsible for the use and treatment granted by them.

In this regard, this Agency indicates that, in this specific sanctioning procedure, an infringement is not being attributed for the mere leaking of images, but for lacking appropriate technical and organizational measures to ensure a level of security adequate to the risk of the treatment, as required by Article 32.1 of the GDPR.

- The SGIP claims that the necessity for broad access profiles originates from the organization and work needs of the General Subdirectorate of Analysis and Inspection, and that regarding the lack of traceability, it is indeed possible to know which person accesses which images - that is, access to the shared folder leaves a trace - the impossibility of identification referred to was regarding the specific person who made the aforementioned images public.

In this regard, this Agency refers to the Report issued by the General Subdirectorate of Analysis and Inspection, which is part of the file, in which point 2 states verbatim (the underlining corresponds to the AEPD):

"Once the images were brought to the attention of the Inspection Unit, they were processed, in compliance with their legally established investigation functions by the Guardia Inspection, the Instructor of Preliminary Information 2021/122, and where the rest of the Inspectors of the Unit could also have accessed them, without it being possible to prove such an extreme."

Therefore, it does not refer, as alleged in the claims, to the impossibility of determining the specific person who made the images public, but rather that it has not even been possible to prove which persons accessed the subsequently leaked images.

It should also be noted that, when this Agency requested information about the records of users who had access to the system (logs), the response was limited to indicating: "The logs of the file server are kept for a specific time, and at this moment, the logs from those dates are not available."

III

Article 32 "Security of processing" of the GDPR states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/12

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the

authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law." In the present case, although it is true that it has not been possible to determine at what moment or by which body that had access to the images the leak occurred, it is evident that the SGIP did not have appropriate measures in place to ensure a level of security adequate to the risk. From the instruction carried out in this procedure, it is concluded that the SGIP has failed to comply with the provisions of Article 32 of the GDPR.

IV

Article 83.4 of the GDPR, under the heading "General conditions for the imposition of administrative fines," states:

"Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/12

total annual global turnover of the previous financial year, opting for the highest amount:

a) the obligations of the data controller and the data processor in accordance with Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a two-year statute of limitations, which involve a substantial violation of the articles mentioned therein, and in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

(...)

V

Without prejudice to the provisions of Article 83.5 of the GDPR, the aforementioned article provides in its paragraph 7 the following:

"7. Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines can be imposed on authorities and public bodies established in that Member State."

For its part, Article 77 "Applicable regime for certain categories of controllers or processors" of the LOPDGDD provides as follows:

"1. The regime established in this article shall apply to the processing for which the following are responsible or act as processors:

a) The constitutional bodies or those with constitutional relevance and the institutions of the autonomous communities analogous to them.

b) The judicial bodies.

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise the Local Administration.

d) The public bodies and entities of public law linked to or dependent on the Public Administrations.

e) The independent administrative authorities.

f) The Bank of Spain.

g) The public law corporations when the purposes of the processing relate to the exercise of public law powers.

h) The public sector foundations.

i) The Public Universities.

j) The consortiums.

k) The parliamentary groups of the General Courts and the legislative assemblies of the autonomous communities, as well as the political groups of the Local Corporations.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed.

3. Without prejudice to the provisions of the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that is applicable.

Furthermore, when the infringements are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible party and shall order publication in the Official State Gazette or the corresponding autonomous gazette.

4. The resolutions related to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities.

(...)"

VI

In accordance with the provisions of Article 58.2 d) of the GDPR, each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, when appropriate, in a specified manner and within a specified time frame...".

Therefore, the party being addressed must proceed, within 6 months from the receipt of this resolution, to adopt the necessary measures to ensure that records of access to personal data are maintained, as well as the granting of profiles to officials so that each can only access the information necessary for the performance of their duties.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/12

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE

on the GENERAL SECRETARIAT OF PENITENTIARY INSTITUTIONS, with NIF S2813060G, for an infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR, a warning sanction.

SECOND: TO ORDER

the GENERAL SECRETARIAT OF PENITENTIARY INSTITUTIONS, with NIF S2813060G, that pursuant to Article 58.2.d) of the GDPR, within a period of 6 months, it must demonstrate that it has adopted the necessary measures to ensure that there are records of access to personal data, and also the granting of profiles to officials so that each can only access the information necessary for the performance of their duties.

THIRD: TO NOTIFY this resolution to the GENERAL SECRETARIAT OF PENITENTIARY INSTITUTIONS.

FOURTH: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

938-010623

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/12